

PRODUCT FRAMEWORK MAPPING

Orvesian governance control map

Product capability assessment and build plan against NIST agent identity work, COSAiS, and relevant EU AI Act provisions.

Purpose and conclusion

Orvesian already creates useful, independently checkable evidence for selected agent activity. Its present architecture supports event intake, scoped review, monitoring prototypes and cryptographic receipts. The main product gap is the chain of authority and completeness around an event: who authenticated the workload, who delegated which authority, whether the action was actually observed, and whether the relevant controls were effective.

Recommended positioning: “Orvesian provides an independent audit and non-repudiation layer for autonomous AI agents.” Qualify this with what the service proves: accepted record integrity and anchor inclusion. A receipt alone does not establish agent identity, authorisation, source truth, complete capture, safe behaviour or legal compliance.

Recommended product direction

- Make agent and deployment identity a first-class control-plane object, backed by authenticated workload identity and a dated owner relationship.
- Record delegated authority and effective policy decisions as linked, versioned evidence; distinguish evidence collection from enforcement in the customer runtime.
- Add capture coverage, event sequence, source and freshness signals so missing observations are visible alongside valid receipts.
- Turn framework mappings into versioned control packs with applicability decisions, evidence links, freshness and explicit gaps.
- Ship production foundations before compliance dashboards: customer identity, role/key lifecycle, PostgreSQL, backups, retention, monitoring and security review.

How to read the assessment

Status	Meaning
Implemented locally; pilot running	Evidence path exists in the private synthetic testnet pilot; it is not a production control assurance.
Partial	Some relevant data, workflow or local alpha exists; key control properties, deployment, coverage or independent authentication remain incomplete.
Gap	No product capability was found that can currently generate the required evidence or perform the described function.

Scope note: assessed against the Orvesian materials available in the workspace at 28 September 2026, including architecture, roadmap, event schema, agent registry, key management, review and local rules/incidents documentation. Status describes product evidence observed in those materials; it is not a legal applicability decision or external audit.

Framework scope and legal boundaries

NIST agent identity and authorisation work

NIST's February 2026 AI Agent Standards Initiative and NCCoE concept paper describe emerging work, not a final certification scheme or mandatory control catalogue. The concept paper explicitly explores identification, authentication, authorization, delegation, logging/transparency, data-flow provenance and prompt-injection prevention or mitigation. It asks how those principles apply in enterprise agent architectures and names standards and approaches for exploration. Orvesian should map to the topics and update the crosswalk as NIST publishes implementation guidance.

NIST COSAiS

COSAiS develops SP 800-53 control overlays for AI system contexts. NIST's project identifies single-agent and multi-agent use cases. Treat overlays and discussion materials as evolving guidance; cite the precise published version used for each mapping and do not imply a COSAiS attestation.

EU AI Act

For qualifying high-risk systems, Article 12 requires technical logging capability throughout the system lifetime and relevant traceability; Article 13 concerns information to deployers; Article 14 covers effective human oversight; Article 18 specifies provider documentation retention; Article 19 concerns provider retention of automatically generated logs under their control; Article 26 assigns deployer duties, including human oversight, monitoring and retention of logs under their control; Article 72 concerns provider post-market monitoring; Article 73 sets serious-incident reporting duties. These obligations attach to defined actors and systems. Orvesian can help produce evidence; it cannot determine classification or transfer the customer's statutory duties.

Under the consolidated EU text and Commission timeline checked for this document, the Act's general application date is 2 August 2026, with specified high-risk Annex III rules applying 2 December 2027 and specified Annex I product-related high-risk rules applying 2 August 2028. Confirm the relevant system category, role and current law before applying a date to an individual customer.

Where blockchain fits

The chain is a public timestamped commitment layer for the exact accepted record. It can make later alteration of that record detectable when the opening, signature and proof are checked against the expected contract and chain. It does not witness source events, validate the authority behind an action, prove that no events were omitted, or make an inaccurate customer assertion true. The product should preserve this boundary in receipts, dashboards and marketing.

Framework-to-product view

Framework need	Orvesian contribution	Boundary
Agent identity and delegation	Registry references, ownership metadata, future workload principal and grant evidence.	Registry references are not yet authenticated workload identity or effective runtime authority.
Logging and traceability	Structured accepted event, searchable scoped history and evidence export.	Customer-configured telemetry may be incomplete; raw source activity stays customer-held.
Integrity and audit	Signed commitment, private proof, independent chain check.	Integrity of accepted bytes, not source truth or completeness.
Human oversight and monitoring	Reviews, outcome history, rules and incident workflow.	Some alpha functions are local-only; no safe stop or runtime enforcement.
Control reporting	Proposed control catalogue and evidence status.	Coverage evidence is not compliance certification or legal advice.

Current product baseline

Capability	Observed implementation	Product status
Event intake and tenancy	Authenticated bounded JSON ingestion, tenant/project scope, event plus outbox transaction, duplicate-safe retries.	Synthetic private pilot; production identity/provisioning unfinished.
Agent/deployment registry	Tenant-scoped agentRef, environment, deployment, owner, purpose, model/config and heartbeat metadata.	Local alpha, not deployed on VPS; metadata is not attested.
API keys	Scoped project read/write keys with hash storage, expiry, rotation and revocation.	Local service capability; customer onboarding/production rollout is incomplete.
Signed evidence	Salted commitment over accepted record and receipt signature; private Merkle proof and Base Sepolia verification.	Independent check of accepted bytes and anchor membership; recorder attestation.
Human review	Authenticated reviewers append structured adjudication/investigation records and history.	Local workspace workflow; not a general approval gate before action.
Rules and incidents	Versioned per-record rules, local processing loop, incident transitions and webhook journal.	Opt-in SQLite alpha; not VPS enabled; PostgreSQL scheduler and production delivery open.
Reporting and export	Scoped reports, linked decisions/reviews, receipt verification and bounded record export.	No framework-control scorecard or full audit dossier.
SDK/event schema	Structured run/model/tool/evaluation observations and framework integrations with filtering.	Capture depends on customer configuration; source content is intentionally excluded.

Design implication: do not expand the immutable event with every raw interaction. Add linked, typed evidence records for identity, grants, policy decisions and oversight actions, and store the smallest useful commitments and references. Keep event and control-plane changes tenant-scoped, exportable and independently verifiable.

Proposed evidence architecture

Evidence object	Minimum fields	Trust and lifecycle rule
Agent identity record	Stable agentRef; tenant/org; owner; provider/deployer role; workload principal; environment; purpose; model/config/deployment refs; status; validity interval.	Separate customer assertion from issuer-verified claim. Append lifecycle changes; retain historical resolution.
Authority grant	Grant ID; human principal; agent/workload; parent grant; resource/action scope; purpose; constraints; approver; issued, expires, revoked times; policy version.	No secret or raw prompt. Per action, resolve the effective grant and show missing/expired authority.
Action observation	Event/run/action ID; authenticated principal; agent/deployment; tool/resource/action; decision/outcome; event time and server receipt time; sequence; source and capture method; parent refs.	Unknown, omitted, failed-to-capture and not-applicable must remain distinct from clear/success.
Policy decision	Policy ID/version/digest; subject and resource refs; requested action; decision; decision point; enforcement point/result; applicable grant.	A recorded allow/deny is not proof of enforcement unless an enforcement response is linked.
Human oversight action	Reviewer/approver principal; target action; approve/reject/override/stop/escalate; reason code; competence/role reference; time; expected revision.	Distinguish prior approval, concurrent intervention and retrospective review.
Evidence receipt	Canonical record digest; recorder key ID; signature; Merkle proof; contract/chain ID; transaction/log reference; confirmation state; verifier version.	Clearly state what was committed and what the verifier did not establish.
Control assessment	Framework and version; control ref; applicability and rationale; evidence links; status; freshness; owner; assessor; as-of time.	Status is derived from explicit evidence rules and freshness, with manual decisions labelled.

Evidence flow

Customer runtime authenticates the workload and enforces its access policy. The instrumentation layer records selected action and decision metadata, filtering source content before transmission. Orvesian validates tenant scope and schema, records server receipt time, and stores the event with its durable outbox. The recorder signs the accepted bytes and anchors a commitment. The workspace links the event to its identity, grant, policy, review, incident and control assessment, while visibly labelling missing or customer-asserted evidence.

Privacy and retention

The existing rule to keep prompts, conversations, documents, media, tool arguments and raw outputs in customer systems remains central. Event metadata may still identify a person or reveal sensitive activity. Add field-level minimisation, retention by data class, evidence export before deletion and a documented treatment for commitments that remain on a public chain after customer-held details are deleted. The customer must select retention consistent with its role and applicable law; the product should not hard-code a universal ten-year event-log period from Article 18, which concerns specified provider documentation.

Control matrix 1

Controls ID-01 to ID-05 | Identity and inventory

Control and source	Status / priority	Evidence today	Build or amend	Acceptance evidence
ID-01 Unique agent identity NIST identity concept	Partial P1	Agent/deployment registry stores tenant-scoped agentRef, environment, deployment, owner, purpose, model/config version and heartbeat; local alpha, not rolled to VPS.	Publish a stable identity lifecycle: create, verify, suspend, retire; prevent caller-chosen collisions and show registry provenance.	Versioned agent inventory; authenticated registry action; lifecycle timestamps and state; registry-to-event reconciliation.
ID-02 Owner and accountable organisation NIST identity concept; EU AI Act Arts 11, 13	Partial P1	Registry captures ownerRef; workspace and project scope events. Ownership semantics, verified person/org binding and historical ownership are not established.	Bind agent owner to verified organisation/workspace membership; preserve dated ownership transfer and accountable deployer/provider roles.	Identity-provider subject and organisation reference; signed owner-change event; historical resolution for prior activity.
ID-03 Agent, model, version and deployment linkage NIST identity concept	Partial P1	Structured events and registry carry model/configuration/deployment references; client-reported metadata is not independently attested.	Normalize lifecycle versions and validity intervals; distinguish observed, customer-asserted and platform-verified attributes.	Versioned deployment manifest, provenance label, activation/retirement events, linked event samples.
ID-04 Human versus workload identity NIST identity concept	Gap P1	Session identities exist for workspace users; a registered agent reference is metadata, not an authenticated workload principal.	Introduce workload credentials or federated workload identity; separate agent principals from human users and project ingest keys.	Credential issuance, binding, expiry, revocation and authentication decision records; negative tests for impersonation.
ID-05 Identity lifecycle and inventory health NIST identity concept	Partial P2	Local registry and heartbeat metadata exist; liveness is not a fleet-wide guarantee and registry is not anchored or deployed.	Deploy registry and freshness monitoring; define stale, suspended and retired states and alert on unknown or duplicate agents.	Inventory snapshots, heartbeat freshness, stale-agent report, lifecycle audit history.

Control matrix 2

Controls AUTH-01 to AUTH-06 | Authentication and authority

Control and source	Status / priority	Evidence today	Build or amend	Acceptance evidence
AUTH-01 Authenticate each workload NIST identity concept; NIST SP 800-207 references	Gap P1	API bearer keys authenticate tenant/project ingestion, not a cryptographic identity for the originating agent; recorder signing key attests to accepted bytes only.	Add workload-auth options such as short-lived scoped credentials or federation; bind authenticated workload identity to submitted agent/deployment refs.	Auth principal, credential issuer/key ID, assurance, request-to-agent binding and verification outcome in protected logs.
AUTH-02 Credential issue, rotate, revoke NIST identity concept	Partial P1	Project API keys support scoped read/write, expiry, rotation and revocation locally; agent credentials, provider-backed customer identity and production deployment are absent.	Complete managed customer identity and production key management; provide separate workload credential lifecycle and rapid revocation.	Key lifecycle records, expiry/revocation enforcement, rotation tests and audit export; no secret values in evidence.
AUTH-03 Least privilege and resource scope NIST identity concept	Partial P1	Tenant/project isolation and ingestion scopes exist. Governance admin, review and key-management roles are distinct; tool-level agent grants are not modeled/enforced.	Add versioned, resource-specific policy grants for tools/data/actions and check at enforcement point; keep Orvesian evidence separate from policy enforcement.	Policy snapshot/ref, subject/resource/action/scope, decision, enforcement source and denied-attempt record.
AUTH-04 Delegated human authority NIST identity concept	Gap P1	Human reviews are authenticated and attributable, but there is no authority grant linking a user, agent, purpose, scope and validity window.	Add explicit delegation records, bounded purpose/resource/action, expiry, limits, approval and revocation; propagate delegation through child agents.	Immutable grant/revoke records and per-action link to grant, authenticated delegator and effective scope.
AUTH-05 Sub-agent delegation chain NIST identity concept	Gap P2	Parent event refs can link records, but the system does not establish or validate multi-agent delegation chains.	Model parent/child workload identity and delegated authority; reject missing, expired or over-broad parent grants and retain chain on each action.	Complete path from human grant through parent and child identities to action; invalid-chain tests.
AUTH-06 Policy changes and decision trace NIST identity concept	Partial P1	Local rule definitions are versioned and prospective; they are operational detection rules, not runtime access policies, and are not yet anchored.	Keep policy decision records distinct from detection rules; preserve the exact effective policy version and enforcement result with each action.	Versioned policy manifest, effective interval, decision input references and signed decision evidence.

Control matrix 3

Controls AUD-01 to AUD-07 | Action capture and audit trail

Control and source	Status / priority	Evidence today	Build or amend	Acceptance evidence
AUD-01 Record attributable agent actions NIST identity concept; AI Act Art 12	Partial P1	Bounded structured run, decision and tool observations enter an atomic outbox and evidence pipeline; customer instrumentation may omit actions.	Define a stable action/event contract and lifecycle semantics; capture authenticated actor, agent, run, tool/action, result and capture source.	Accepted event linked to workload principal, schema/version and receipt; explicit unknown/omitted states and completeness coverage.
AUD-02 Record intent and context safely NIST identity concept; AI Act Art 12	Partial P1	Purpose, profile, model/config and structured metadata can be recorded; raw prompts, arguments and outputs are deliberately kept customer-side.	Add privacy-preserving intent/purpose and context provenance fields, external trace refs and minimization guidance; avoid representing hashes as semantic proof.	Purpose/policy refs, input-source references or commitments, privacy review and field-level provenance.
AUD-03 Retain complete required logs AI Act Arts 12, 19, 26(6)	Gap P1	Orvesian accepts selected governance records; it is not the system of record for source runtime logs. Retention policy and production backup are not finished.	Provide configurable retention/export and evidence-preserving deletion controls; let customers map obligations to source logs and retention responsibility.	Retention configuration, coverage/omission view, export reconciliation, restore evidence and deletion audit.
AUD-04 Timestamp and event ordering NIST identity concept; AI Act Art 12	Partial P1	Server receipt time is included in signed evidence; customer occurredAt and per-agent sequence exist in schema/SDKs but do not establish trusted source time on their own.	Record occurred, observed, received and anchored times distinctly; validate monotonic sequence and clock-skew policy; preserve late-arrival handling.	Timestamp source/quality, sequence gaps, receipt time, anchor time and reconciliation results.
AUD-05 Trace data flow and provenance NIST identity concept	Partial P2	Event profile and external trace references can describe structured context; source data, prompts and full provenance graph remain customer-held.	Add typed provenance links for input source, transformation, model, tool and output commitments; declare absent links explicitly.	Provenance graph export with source and trust labels; no raw content leakage in transport/logs.
AUD-06 Reconstruct an investigation NIST identity concept; AI Act Arts 11, 12	Partial P1	Scoped workspace links decisions, reviews and receipts; filters and exports work. End-to-end source trace completeness and dedicated incident reconstruction are limited.	Unify event, deployment, policy, grant, review, incident and receipt timelines with bounded, tenant-scoped investigation export.	Repeatable case export, lineage links and export verification result; access audit.
AUD-07 Detect gaps and tampering NIST identity concept; AI Act Arts 12, 19	Partial P1	Signed salted commitments and private Merkle proofs are independently checkable against Base Sepolia; this proves accepted bytes match commitment, not truthful or complete capture.	Add explicit sequence/capture-gap detection, reconciliation with customer source counters and anomaly reporting; retain verifier outcomes and chain parameters.	Tamper verification, gap/reconciliation report, independent receipt validation and documented trust boundary.

Control matrix 4

Controls NR-01 to NR-04 | Non-repudiation and evidence integrity

Control and source	Status / priority	Evidence today	Build or amend	Acceptance evidence
NR-01 Integrity of accepted evidence NIST identity concept	Implemented locally; pilot running P1	Recorder signs salted commitment over accepted event and receipt proofs can be checked against Base Sepolia; 2,400 synthetic soak records were recorded in the project status.	Keep recorder signing attestations distinct from source-agent authentication; document key custody, rotation, compromise response and verification semantics.	Event opening, commitment, signature, Merkle proof, matching chain event and verifier report.
NR-02 Bind action to authenticated actor NIST identity concept	Gap P1	Receipt identifies the recorder as signer; it does not cryptographically bind the submitting workload, human grant or runtime action.	Bind accepted record to workload-auth result and delegation/policy evidence; consider customer signatures or federated assertions with explicit assurance level.	Signed or verified actor assertion, grant ref, credential key ID and independent validation result.
NR-03 Protect policy and control history NIST identity concept	Gap P1	Local rule and incident journals are append-only with version/action checks but rule artefacts and transitions are not yet signed or anchored.	Commit policy/rule artefacts, activation and incident lifecycle changes to evidence pipeline; retain immutable version references and rollback rationale.	Version digest and receipt for create/change/activate/revoke plus incident transitions.
NR-04 Long-term export and verification AI Act Art 18; NIST audit	Partial P2	Single-record evidence exports support independent checks; production retention, long-term archive continuity and evidence-key trust publication remain open.	Define customer-specific retention, archive format, key rollover/trust bundle and verifier version policy; support export before deletion.	Long-lived package test, archived trust chain, versioned verifier and retrieval/retention evidence.

Control matrix 5

Controls HUM-01 to HUM-04 | Human oversight and review

Control and source	Status / priority	Evidence today	Build or amend	Acceptance evidence
HUM-01 Capture human approval and intervention AI Act Arts 14, 26(2)	Partial P1	Workspace reviewers can append a structured adjudication or investigation record with server-derived reviewer reference; no general pre-action approval gate.	Add approval request/outcome/override/escalation event types and link each decision to the action; distinguish retrospective review from prior approval.	Authenticated actor, timestamp, object/action, decision, reason code, policy/grant and linked receipt.
HUM-02 Support stop, override and safe intervention AI Act Arts 14, 26(2)	Gap P1	Review UI and incident acknowledge/resolve/reopen records do not pause or stop an executing system.	Integrate a customer-controlled enforcement/kill-switch callback with explicit authority, safe-state response and outage behavior; expose integration health.	Requested and observed stop signal, runtime acknowledgement, safe-state result and response latency.
HUM-03 Explain limitations and uncertainty AI Act Arts 13, 14	Partial P2	Reports label descriptive metrics and distinguish missing/conflicting review data; no role-specific system transparency dossier.	Provide versioned deployment cards: intended use, limits, meaningful inputs/outputs, evaluation scope, known failure modes and human oversight instructions.	Approved documentation version linked to system/deployment and change history.
HUM-04 Show human coverage and review state AI Act Arts 14, 26(2)	Partial P2	Review queues show awaiting, reviewed, investigation, conflicts and missing metadata for selected windows.	Measure overdue reviews, required-human approval coverage and unresolved high-risk actions; define denominators and escalation thresholds.	Windowed metrics with denominator, freshness, sampling and missingness explanation.

Control matrix 6

Controls MON-01 to MON-04 | Monitoring and incident response

Control and source	Status / priority	Evidence today	Build or amend	Acceptance evidence
MON-01 Evaluate operational rules NIST COSAIS; AI Act Arts 12, 72	Partial P1	Versioned per-record rules and bounded local processing can detect submitted failed runs, latency and tool permission/failure observations; no drift or continuous source coverage claim.	Deploy PostgreSQL-capable scheduled processing, validated domain metrics, baseline/trend checks and explicit no-data/incomplete states.	Rule/version, evaluated denominator, matched/missing/not-applicable counts, processing lag and provenance.
MON-02 Operational monitoring and alerts NIST COSAIS; AI Act Art 72	Partial P1	Local SQLite opt-in rules/incidents and webhook journal exist; not enabled on VPS, no production alert service/destination setup.	Deploy durable processors, service metrics, retry/dead-letter review, tenant destinations, alert delivery proof and escalation policy.	Cycle and backlog metrics, delivery attempts/outcomes, test alert and restart/recovery evidence.
MON-03 Incident lifecycle and investigation NIST identity concept; AI Act Arts 72, 73	Partial P1	Local tenant-scoped incidents support acknowledge, resolve, reopen with revisioned history; no owner, full-history pagination or production deployment.	Add ownership, evidence bundle, impact/risk assessment, corrective action, notification deadlines and end-to-end regulatory-report support as customer workflow.	Timeline, append-only actions, linked events/receipts, impact assessment and exportable report package.
MON-04 Serious incident reporting support NIST identity concept; AI Act Art 73	Gap P2	No deadline-aware statutory reporting workflow; Orvesian alerting is not notification to an authority.	Add configurable awareness/causal-link dates, deadline calculation, escalation and draft/export tracking; customer remains responsible for report and submission.	Incident clock, responsible actor, report version, submission reference and timing history.

Control matrix 7

Controls SEC-01 to SEC-04 | Security, privacy and prompt injection

Control and source	Status / priority	Evidence today	Build or amend	Acceptance evidence
SEC-01 Record security signals, including prompt injection NIST identity concept; COSAIS	Gap P2	Prompt-injection detection/mitigation is not provided; generic structured records may carry customer-reported security events.	Define optional security-event taxonomy and safe references; integrate customer detector outputs with confidence/source labels; avoid claiming detection if only submitted.	Source detector/version, observed indicator, action taken, confidence and receipt; explicitly identify submitted versus detected.
SEC-02 Constrain data, tool and egress access NIST identity concept; COSAIS	Gap P1	MCP and tool observations record limited status; Orvesian does not grant or enforce customer runtime permissions or prevent injection.	Provide policy integration points and enforcement adapters; customer runtime must enforce least privilege, isolation and output/egress controls.	Policy decision and actual enforcement response linked to tool call; denied and bypass tests.
SEC-03 Minimise sensitive source data AI Act Arts 10, 12; GDPR principles	Partial P1	SDKs filter prompts, tool arguments/results and sensitive payloads; accepted structured metadata can still be personal or sensitive.	Ship field allowlists, PII minimisation guidance, tenant retention and deletion/export controls; complete privacy review and safeguards for immutable anchors.	Schema/filter tests, data map, retention setting and deletion workflow evidence.
SEC-04 Protect tenant and service operations COSAIS; platform security baseline	Partial P1	Tenant-scoped API, sessions, roles, local Postgres/RLS validation, trusted gateway and limited-balance relay are described; production hardening and identity integration remain gates.	Complete managed SSO/MFA, environment separation, PostgreSQL deployment, encrypted backup/restore, security monitoring and independent review.	Cross-tenant/role abuse results, recovery drill, configuration evidence, incident/key runbook.

Control matrix 8

Controls REP-01 to REP-04 | Control evidence and reporting

Control and source	Status / priority	Evidence today	Build or amend	Acceptance evidence
REP-01 Map control to evidence Framework mapping capability	Gap P1	Records and receipts exist, but there is no governed framework/control catalogue with applicability, evidence requirements and status logic.	Create versioned framework packs and customer-mappable controls with citations, applicability decisions, owner, assessment date and evidence links.	Framework/control version, applicability rationale, linked evidence IDs and assessor decisions.
REP-02 Calculate evidence coverage honestly NIST COSAIs; EU AI Act	Gap P1	Existing descriptive reporting measures events/reviews; it does not calculate framework control coverage or legal compliance.	Build statuses: evidenced, partial, missing, not applicable, stale, disputed; calculate coverage from current required evidence and show provenance/denominator.	Reproducible snapshot, ruleset version, as-of time, evidence freshness and gap list.
REP-03 Export auditor-ready evidence AI Act Arts 11, 18, 19, 72	Partial P2	Workspace provides bounded evidence exports; no complete control dossier or formal technical/QMS documentation repository.	Produce access-controlled, versioned evidence packs with source references, verifier checks, caveats, retention date and export audit record.	Export manifest, hash checks, control crosswalk, access log and reproducible regeneration.
REP-04 State claim boundaries Product positioning	Partial P1	Architecture documentation already distinguishes signed accepted bytes from truthful/complete capture, safety, identity and enforcement.	Put these boundaries in product UI, evidence export and sales language; avoid compliance certification or universal conformance claims.	Claim review, in-product provenance labels and examples of evidence limits.

Build sequence and release gates

Wave	Build package	Acceptance gate
0 Production foundations	Finish environment separation, production identity/SSO/MFA choice, customer workspace provisioning and scoped key lifecycle; deploy PostgreSQL, encrypted backups, restore drill, retention, quotas and security monitoring.	Cross-tenant and role abuse checks pass; keys revoke; backup restore is repeatable; no unapproved public exposure; operational owner and incident/key runbooks exist.
1 Trustworthy identity and delegation	Agent registry rollout; bind authenticated workload principal to agent/deployment; explicit human grants with scope/expiry/revocation; delegated-agent chain; source-assurance labels.	Valid and invalid credentials/grants tested; each action resolves an actor and authority or records a reasoned gap; tenant boundaries hold.
2 Event coverage and policy evidence	Versioned action/provenance schema; sequence and time-source semantics; capture health/gap report; link decisions to runtime enforcement results; privacy allowlists.	End-to-end trace from representative runtime action; deliberately omitted/failed capture is visible; sensitive source fields are filtered; enforcement claims match runtime response.
3 Monitoring and incidents	Deploy PostgreSQL-capable rule processor, durable incident lifecycle, service metrics, alert delivery/retry/dead-letter, owner and regulatory clock support.	Restart/outage/replay tests; processing lag and denominator shown; test alert delivered; incident chronology and evidence export reconcile.
4 Framework evidence workspace	Version NIST/EU control packs, applicability workflow, evidence links, freshness and honest status model, assessor actions, export and independently verifiable evidence pack.	Every status traces to current evidence and a rule; stale and conflicting evidence remains visible; regenerate export and validate receipts independently.
5 Security and customer pilot	Threat model prompt injection/delegation/credential theft; independent security and privacy review; run one design-partner workflow through operation, oversight and incident response.	Document known limitations and remediation; demonstrate operational recovery, customer ownership and human intervention; approve production claims and support boundaries.

Priority interpretation

P1 items support the core proposition or close foundational security and evidence gaps. P2 items deepen lifecycle, reporting or domain coverage after identity and evidence integrity work. This ordering is a product recommendation based on dependencies in the current architecture, not a NIST or legal ranking.

Product release claims to preserve

- “Verifies that this accepted record matches its signed commitment and checked anchor.”
- “Shows the evidence Orvesian received, the source that supplied it, and identified gaps.”
- “Maps selected evidence to a versioned governance framework for customer assessment.”
- Avoid “proves agent compliance,” “prevents prompt injection,” “complete audit trail,” or “AI Act compliant” unless a defined deployment has separately substantiated that claim.

Source documents and product references

Framework sources were checked on 28 September 2026. NIST materials are initiative or project material and may change. EU AI Act applicability depends on system classification, actor role, intended purpose and the applicable consolidated law. This product mapping is not legal advice or a conformity assessment.

[EU AI Act consolidated text, Regulation \(EU\) 2024/1689, version 27 July 2026](#)

Primary legal text used for Articles 12–14, 18–19, 26, 72–73 and amended dates.

[European Commission AI Act implementation timeline](#)

Commission summary: main provisions apply from 2 August 2026; current high-risk dates include 2 December 2027 (Annex III) and 2 August 2028 (Annex I product-related).

[NIST AI Agent Standards Initiative, February 2026](#)

Initiative announcement; standards work is emerging, not a binding control set.

[NIST NCCoE Software and AI Agent Identity and Authorization concept paper, February 2026](#)

Draft concept seeking comment; identity, authentication, authorization, delegation, logging, provenance and prompt injection are areas of interest.

[NIST agent identity foundation blog, 27 August 2026](#)

NIST identity direction and accountability discussion; not itself a standard.

[NIST COSAiS project](#)

NIST SP 800-53 control-overlay project; planned use cases include single-agent and multi-agent systems. Overlay work is evolving.

Orvesian materials reviewed

- docs/platform-architecture.md: event intake, testnet evidence, deployment boundaries, reporting and operational limits.
- docs/roadmap-and-decisions.md: production foundations, customer onboarding, identity and key management sequence.
- docs/governance-rules-and-incidents.md: local rules, incident states, processing, webhook and deployment limitations.
- services/governance/agents.cjs and migrations/003-agent-registry.sql: tenant-scoped agent, deployment and heartbeat metadata.
- services/governance/project-keys.cjs and project-key-routes.cjs: scoped API key create, rotation, expiry and revocation behaviour.
- services/governance/reviews.cjs: authenticated structured review and append-only review evidence.
- services/governance/evidence.cjs, evidence-provider.cjs and worker.cjs: signed commitment and anchor processing path.
- spec/governance/governance-event-v0.1.0-draft.schema.json and spec/verification-receipt/: event and evidence contracts.

Suggested next working artifact

Convert this product crosswalk into a versioned machine-readable control catalogue and evidence contract after the identity/delegation design is agreed. Keep framework source/version, exact clause reference, applicability rationale, product owner, evidence schema, freshness rule and testable acceptance criterion as separate fields.